Deliverable 3 of 7

Requirements Gathering

AWS Threat Detection, Monitoring, Incident Response & Forensics

DEPI – AWS Security Cloud Computing Track – Project 4

#	Team member	Role
1	Kareem Mohamed Abdalmged	Team Lead, IaC & Documentation
2	Adham Ramzy Mohamed Eltohamy	Threat Detection Engineer
3	Hossam Abdelghany Mostafa	Incident Response & Forensics Engineer
4	Alaa Ahmed Ramadan	Logging & Audit Engineer
5	Amira Ashraf Saber	Automation & Reporting Engineer

Instructor: Ahmed Gamal | Submission due: 16 October 2026 | Version 1.0

1. Context

The project models a fictional mid-sized company, NileTech, that runs a customer web application on AWS: an internet-facing load balancer, a web server in a public subnet, an application server in a private subnet, an Amazon RDS database with customer data, EBS volumes, and an S3 data bucket accessed with IAM users and access keys. NileTech has little audit visibility and no rehearsed incident response. Requirements below are written for that scenario and trace back to the four weeks of DEPI Project 4. The assets to protect are the web and application servers, the RDS customer data, EBS volumes, the S3 data bucket and the IAM users and access keys.

2. Stakeholder Analysis

Stakeholder	Interest / needs	Influence	How the project serves them
DEPI instructor / evaluator	All deliverables complete, each member's contribution visible, working demo	High	Documentation set on GitHub, per-member ownership, live demo
CISO / security team (NileTech)	Visibility into activity, early detection, a tested incident response process	High	Central logging, detection services, IR playbooks, automated response
SOC analysts / incident responders	Searchable logs, triaged findings, clear playbooks and fast containment	High	Athena queries, Security Hub, Detective, playbooks, SOAR automation
Compliance / audit	Complete, tamper-evident audit trail and configuration history	Medium	Organization trail with validation, Config recorder, retention policy, log inventory
Cloud / DevOps engineers	Repeatable, documented environment that is easy to change	Medium	Terraform modules, tagging, documented IAM roles
Application owners / data owners	Protection of customer data without disruption to the application	Medium	Macie and Inspector findings, scoped automation, containment checklist
Executive management	Clear understanding of incident impact, cause and lessons learned	High	Executive summary and final IR report
Finance	Predictable cloud cost	Medium	AWS Budgets, staged enablement of detection services
Website customers	Their data stays safe and the service stays available	Low	Faster detection and containment of compromise

3. User Stories

Format: As a <role>, I want <goal> so that <benefit>. Each story has acceptance criteria that become test cases.

ID	User story	Acceptance criteria
US-01	As an auditor, I want an organization trail covering all accounts and regions so that every API call is recorded and cannot be disabled by member accounts.	Trail status is logging; multi-region and organization options on; log file validation on; digest files appear in S3.
US-02	As a compliance officer, I want AWS Config to record resource configuration changes so that I can see what changed and when.	Recorder is on; changing a test security group appears in the Config timeline.

ID	User story	Acceptance criteria
US-03	As a SOC analyst, I want VPC Flow Logs, S3 server access logs and ELB access logs sent to a central archive so that network and access activity is available for investigation.	Objects from each source appear in the log-archive bucket (and CloudWatch Logs where configured) within the expected delivery time.
US-04	As a SOC analyst, I want to query logs with Athena so that I can answer investigation questions quickly.	Saved queries return API calls by user, rejected traffic, S3 object access and ELB 5xx / top client IPs for known test events.
US-05	As a security manager, I want a log retention policy so that logs are kept long enough and cost stays controlled.	S3 lifecycle rules and CloudWatch log group retention are set; audit log inventory lists source, destination, format, retention and owner.
US-06	As a SOC analyst, I want GuardDuty and Security Hub enabled so that threat findings are detected and shown in one place.	Sample findings appear in GuardDuty and are aggregated in Security Hub.
US-07	As a compliance officer, I want Config rules and Trusted Advisor checks so that risky configurations are flagged.	A public test bucket, an open security group and an old access key are reported as non-compliant / flagged.
US-08	As a vulnerability manager, I want Amazon Inspector to scan EC2 instances so that known vulnerabilities are identified.	Inspector findings for the test instance appear in Inspector and Security Hub.
US-09	As a data owner, I want Amazon Macie to scan the data bucket so that sensitive test data is identified.	Macie job completes and reports the planted test data types.
US-10	As an analyst, I want to triage findings, investigate in Detective and map them to MITRE ATT&CK so that priorities and attacker behaviour are clear.	Triage notes with severity, decision and ATT&CK technique for at least 10 findings.
US-11	As an incident responder, I want to isolate a compromised EC2 instance and snapshot its disk so that damage is limited and evidence preserved.	Isolation security group applied; EBS snapshot completed and tagged; done in under 10 minutes.
US-12	As an incident responder, I want to revoke and rotate exposed access keys so that the attacker loses access.	Key deactivated, sessions revoked, new key issued; CloudTrail shows no further use of the old key.
US-13	As an incident responder, I want to block public access on an exposed bucket so that data is no longer reachable.	Block Public Access enabled; anonymous request returns access denied; access logs reviewed.
US-14	As a forensic investigator, I want evidence collected with hashes and chain-of-custody notes so that it is trustworthy.	Evidence stored in the evidence bucket; SHA-256 recorded; custody log has every hand-over.
US-15	As an IR lead, I want playbooks, a containment checklist, a timeline and a root cause analysis so that incidents are handled consistently.	Three playbooks, a checklist, a timeline and an RCA document exist for the simulated incidents.
US-16	As a SOC manager, I want findings to trigger automated containment so that response is faster than manual work.	EventBridge rule fires on a high-severity finding for a tagged instance; Lambda / SSM Automation isolates it, snapshots EBS and sends an SNS email within 2 minutes.
US-17	As an analyst, I want a Security Hub custom action so that I can start the response on demand.	Selecting the custom action on a finding runs the response playbook.
US-18	As an executive, I want a technical IR report and an executive summary so that I understand impact, cause and lessons learned.	Final IR report, executive summary and lessons learned delivered; SOAR design documented.
US-19	As the team lead, I want the whole environment defined in code so that it can be rebuilt and torn down on demand.	terraform apply builds and terraform destroy removes all resources without manual steps.

4. Use Cases

ID	Use case	Primary actor	Main flow	Outcome
UC-01	Audit API activity	Auditor	Console / API call → CloudTrail org trail → S3 log archive and CloudWatch Logs → Athena query	Who did what, when, is provable
UC-02	Investigate network and access logs	SOC analyst	VPC Flow, ELB and S3 access logs → S3 → Athena query	Suspicious sources and objects identified
UC-03	Triage a security finding	SOC analyst	GuardDuty / Inspector / Macie / Config → Security Hub → Detective → triage note and ATT&CK mapping	Finding prioritised and documented
UC-04	Respond to compromised EC2	Incident responder	Alert → isolation SG → EBS snapshot → capture logs → evidence to S3 → timeline	Threat contained, evidence preserved
UC-05	Respond to exposed access keys	Incident responder	Alert → deactivate key and revoke sessions → rotate → review CloudTrail activity	Access removed, activity understood
UC-06	Remediate public S3 bucket	Incident responder	Alert → Block Public Access → review S3 access logs → record findings	Data exposure stopped and assessed
UC-07	Automated response (SOAR)	Security automation	Finding → Security Hub / EventBridge rule → Lambda + SSM Automation → isolate, snapshot, revoke → SNS email	Containment in minutes with notification
UC-08	Report an incident	Security analyst	Timeline and RCA → technical IR report → executive summary → lessons learned	Findings communicated to management
UC-09	Rebuild environment	Team lead	git clone → terraform init / plan / apply → validation tests	Environment recreated from code

Detailed use case diagrams and descriptions are provided in Deliverable 4 (System Analysis & Design).

5. Functional Requirements

Priority uses MoSCoW: M = Must, S = Should, C = Could.

ID	Requirement	Week	Priority
FR-01	Create a CloudTrail organization trail (all regions, management events, log file validation) delivering to the S3 log archive and CloudWatch Logs.	1	M
FR-02	Enable the AWS Config recorder and delivery channel for supported resource types, delivering to S3.	1	M
FR-03	Enable VPC Flow Logs for the workload VPC to S3 (and CloudWatch Logs).	1	M
FR-04	Enable S3 server access logging on the data bucket and access logs on the load balancer, delivered to the log archive.	1	M
FR-05	Create a central log-archive bucket with encryption, versioning, Block Public Access and a least-privilege bucket policy.	1	M
FR-06	Apply a log retention policy using S3 lifecycle rules and CloudWatch log group retention.	1	M
FR-07	Create Athena tables and saved queries for CloudTrail, VPC Flow Logs, S3 access logs and ELB logs.	1	M
FR-08	Produce the log architecture diagram and an audit log inventory (source, destination, format, retention, owner).	1	M
FR-09	Enable Amazon GuardDuty and generate sample findings.	2	M

ID	Requirement	Week	Priority
FR-10	Enable AWS Security Hub with security standards and integrate GuardDuty, Config, Inspector and Macie findings.	2	M
FR-11	Deploy AWS Config managed rules (e.g. public S3 access, restricted SSH, access key rotation, MFA).	2	M
FR-12	Enable Amazon Inspector for the EC2 instances and review findings.	2	M
FR-13	Enable Amazon Macie and run a classification job on the data bucket containing test data.	2	S
FR-14	Enable Amazon Detective and use it to investigate at least one finding.	2	S
FR-15	Review AWS Trusted Advisor security checks available for the account.	2	S
FR-16	Triage sample findings, map them to MITRE ATT&CK and produce a detection baseline.	2	M
FR-17	Simulate a compromised EC2 instance on a tagged instance in an isolated subnet.	3	M
FR-18	Simulate exposed access keys (canary IAM user) and a public S3 bucket (test data only).	3	M
FR-19	Contain the EC2 instance: isolation security group, NACL deny if needed, EBS snapshot, tagging.	3	M
FR-20	Contain the exposed keys: deactivate, deny policy, revoke sessions, rotate, review CloudTrail activity.	3	M
FR-21	Contain the public bucket: enable Block Public Access and review S3 access logs.	3	M
FR-22	Collect evidence into a dedicated evidence bucket with SHA-256 hashes and a chain-of-custody log.	3	M
FR-23	Write IR playbooks (EC2, keys, S3), a containment checklist, an incident timeline and a root cause analysis.	3	M
FR-24	Create EventBridge rules that match GuardDuty / Security Hub findings by type, severity and resource tag.	4	M
FR-25	Implement Lambda functions and SSM Automation runbooks to isolate EC2, snapshot EBS, deactivate keys and notify.	4	M
FR-26	Create a Security Hub custom action that triggers the response on demand.	4	S
FR-27	Send SNS email notifications for every automated action.	4	M
FR-28	Document the SOAR design and the automated response playbook; demonstrate the EventBridge / Lambda flow.	4	M
FR-29	Write the technical IR report, the executive summary and lessons learned.	4	M
FR-30	Define all resources in Terraform stored in GitHub with a README.	All	M
FR-31	Configure AWS Budgets alerts for every lab account.	All	M
FR-32	Use least-privilege IAM roles for responders and automation, and tag lab resources for scoping.	All	M

6. Non-Functional Requirements

ID	Category	Requirement	Measure / verification
NFR-01	Security	Log and evidence buckets are encrypted, versioned, not public and writable only by the logging services and authorised roles.	Bucket policy and Block Public Access review; Config rules
NFR-02	Security	CloudTrail log file integrity validation is enabled and passes.	CloudTrail digest validation
NFR-03	Security	Responder and automation roles follow least privilege; no long-lived access keys or secrets in the repository.	IAM policy review; GitHub secret scanning; .gitignore review
NFR-04	Integrity	Every evidence item has a SHA-256 hash and a chain-of-custody entry.	Custody log review
NFR-05	Observability	All six log sources are enabled and logs are retained at least 30 days.	Audit log inventory; lifecycle and retention settings
NFR-06	Detection	Simulated malicious activity is detected in under 15 minutes.	Simulation timestamp vs finding / alarm time
NFR-07	Performance	Manual containment in under 10 minutes; automated containment in under 2 minutes after the finding event.	IR timeline; Lambda / SSM execution logs
NFR-08	Reliability	Automation is idempotent, scoped by tag, and failures notify the team.	Re-run test; failure test; SNS message
NFR-09	Auditability	Every automated and manual response action is recorded in CloudTrail and notified.	CloudTrail events and SNS emails
NFR-10	Safety	Simulations affect only tagged lab resources; test data only.	Tag review; scope checklist
NFR-11	Maintainability	100% of lab resources reproducible from Terraform; one module per project week.	Clean-account rebuild
NFR-12	Cost	Spend ≤ USD 20 per account per month.	AWS Budgets / Cost Explorer
NFR-13	Usability	README lets a new member deploy the environment in under 30 minutes; playbooks can be followed by a new analyst.	Walkthrough by a team member
NFR-14	Compliance	Controls aligned with the CIS AWS Foundations logging and monitoring recommendations; response process follows NIST SP 800-61 phases.	Checklist and mapping table

7. Assumptions and Constraints

- All work runs in a single AWS region; members use personal free-tier accounts plus one shared team account.
- The organization trail depends on AWS Organizations in the shared team account; if unavailable, a multi-region single-account trail is used.
- Detection services are enabled in the week they are needed to use free trials where offered, and disabled afterwards.
- Trusted Advisor checks are limited to those available on the account's support plan.
- Incidents are simulated only (GuardDuty sample findings and tagged lab resources); no real malware, no attacks on systems the team does not own.
- No real customer or personal data is used; test data only.
- Deadlines follow the DEPI schedule; implementation must be complete by 30 November 2026.

8. Requirements Traceability

Project week	User stories	Functional requirements	Owner
Week 1 – Logging & Audit Foundation	US-01 to US-05	FR-01 to FR-08	M1 – Alaa Ahmed Ramadan
Week 2 – Threat Detection Services	US-06 to US-10	FR-09 to FR-16	M2 – Adham Ramzy Mohamed Eltohamy
Week 3 – Cloud Incident Response & Forensics	US-11 to US-15	FR-17 to FR-23	M3 – Hossam Abdelghany Mostafa
Week 4 – Automation & Executive Reporting	US-16 to US-18	FR-24 to FR-29	M4 – Amira Ashraf Saber
Cross-cutting	US-19	FR-30 to FR-32	M5 – Kareem Mohamed Abdalmged